

Identifikasi Aset, Scope, dan Sistem

- a. Data Medis dan Pasien: Mencakup Nomor Induk Kependudukan (NIK), profil pasien, catatan kasus klinis, dan hasil diagnosis akhir (Consensus). Aset ini dilindungi secara ketat karena masuk dalam kategori Protected Health Information (PHI).
- b. File Media Histopatologi: Citra medis resolusi tinggi yang diunggah oleh operator laboratorium ke dalam sistem penyimpanan awan (cloud storage), yang berfungsi sebagai objek utama dalam proses deteksi AI dan analisis dokter.
- c. Kredensial dan Manajemen Kunci: Meliputi hash kata sandi pengguna (bcrypt), token otentikasi sesi (JWT), dan kunci rahasia lingkungan (AES-256 keys, RSA Private/Public keys, dan API keys Supabase) yang menjamin akses ke sistem.
- d. Audit Log: Catatan historis (append-only) dari seluruh mutasi data dan tindakan kritis medis untuk memastikan akuntabilitas (mencegah repudiation) dari setiap pengguna yang berinteraksi dalam sistem.

Ancaman Utama (Framework STRIDE)

Kategori Threat	Deskripsi Threat	Tingkat Risiko
Spoofing	Penyerang berhasil mencuri token JWT pengguna sah (misalnya melalui serangan XSS di klien) untuk mengambil alih sesi dan menyamar sebagai Dokter atau Operator.	Sedang
Tampering	Penyerang mencegat dan memanipulasi payload diagnosis saat data ditransmisikan (MiTM), atau mengeksploitasi presigned URL untuk menimpa citra histopatologi di storage.	Kritis
Repudiation	Pengguna yang sah (misal: Dokter Patologi) menyangkal telah melakukan validasi atau Consensus medis akibat tidak adanya bukti log sistem dan tanda tangan digital.	Tinggi
Information Disclosure	Kebocoran data rekam medis dan NIK pasien akibat eksploitasi celah Insecure Direct Object Reference (IDOR) yang gagal membatasi akses antar-institusi.	Kritis
Denial of Service	Penyerang melumpuhkan ketersediaan sistem dengan melakukan spamming pada API request atau mengunggah citra medis berskala masif untuk menghabiskan kuota bandwidth.	Tinggi
Elevation of Privilege	Operator Laboratorium mengeksploitasi middleware atau parameter sistem untuk mem-bypass Role-Based Access Control (RBAC) agar mendapatkan hak akses setara Dokter.	Sedang

Threat Model Diagram

